

Jour 1 : l'alerte phishing révèle une intrusion vieille de trois semaines

7

pièces analysées

5

preuves

2

bruits

21j

de présence de l'attaquant

0/8

sessions VPN avec MFA



A-11

Alerte SOC « phishing »

PREUVE

Courriel vers la direction financière, avec faux

A-01

FIN-112 déjà infecté

PREUVE

Mirage A Chiffre depuis la veille : le

A-02

Entrée réelle : le VPN

PREUVE

8 sessions de nuit, sans MFA, depuis l'étranger

Constat

L'impact devient visible

PREUVE

Fichiers Chiffres sur le partage comptable : la

A-05

Sauvegardes sabotées

PREUVE

Veeam Backup non modifiée, 3 nuits sans

Le compte VPN du prestataire vit la nuit

A-02

Attendu

09h-18h

Observé

01:57-05:01

00h

06h

12h

18h

24h

Les 8 sessions, de J-21 à J-1, tombent toutes hors des heures ouvrées, depuis l'étranger, sans aucune MFA.

Bruits écartés

2 pièces

A-19

BRUIT

Clé USB piégée, jamais branchée.

A-17

BRUIT

Copie de la paie autorisée.

ticket #4471 · 44 Mo

Questions ouvertes en fin de journée

Q1

Veeam · J-3

Action sans session VPN ce jour-là : par quel accès ?

Q2

vssadmin

Date incohérente avec la chronologie.

Jour 2 : 23 serveurs chiffrés, 117,8 Go volés, et dix fausses alertes à trier

La nuit du J-1, minute par minute

A-10 · A-12 · A-04

02:15

Session VPN ouverte

svc_oasisnet

03:11

Privilèges élevés

03:12

Lancement de svhost32.exe

03:13

Lecture de 9 412 fichiers

03:14

Connexion au C2

45.137.184.62

03:15

• .mirage sur 14 partages

• Sauvegardes locales détruites

• Antivirus arrêté

• Note de rançon créée

A-04

PREUVE

Note antidatée (timestamping).
La table MFT garde la vraie date :
J-1 03:15:39

03:16

Journal de sécurité effacé

04:35

Fin de session VPN

15

pièces analysées

5

preuves

6

bruits

4

fausses pistes

23 serveurs chiffrés sur 40

A-13

23/40

chiffrés

23 chiffrés

Paie, facturation, ERP, partages

2 partiels

Messagerie, DC-01

15 non chiffrés

Dont le SCADA, isolé

Le canal d'exfiltration

A-09 · A-03

Sources

FIN-112

FILER-RBT

Règle pare-feu

OUT-TEMP-443

C2 attaquant

45.137.184.62

Règle créée par l'attaquant à J-11, sans journalisation. Balise toutes les 60 s : 117,8 Go exfiltrés en 10 nuits.

Données chiffrées ET volées : c'est une double extorsion.

Pièces écartées

10 / 15

FAUSSE PISTE × 4

A-20

Mail de migration légitime, DKIM valide.

A-16

Faux DDoS : des lecteurs venus d'un article de presse. **L'incident est donc public.**

A-14

Badgeuse non fiable.

A-23

Fraude au président, sans lien avec l'intrusion.

BRUIT × 6

A-41

Intervention du support IT.

A-21

Scans Shodan / Censys.

A-40

Ticket d'un autre client.

A-26

Directeur en déplacement.

A-25

PsExec légitime.

A-22

Faux positif sur 7-Zip.

ACTIONS

1 · CONTENIR → 2 · PRÉSERVER → 3 · ÉRADIQUER → 4 · RESTAURER → 5 · INFORMER